

1. Cel ćwiczenia

Celem ćwiczenia było zbudowanie własnego środowiska SIEM (Security Information and Event Management) opartego na stosie Elastic (Elasticsearch + Kibana) oraz zasymulowanie wybranych scenariuszy ataków z wykorzystaniem frameworku Atomic Red Team. Zadanie podzielone było na dwa terminy: przygotowanie środowiska oraz realizację czterech scenariuszy ataków wraz z ich analizą i dokumentacją.

Główne cele zadania obejmowały:

- Wdrożenie Elasticsearch i Kibana jako platformy SIEM na maszynie wirtualnej z Ubuntu Server.
- Skonfigurowanie maszyny wirtualnej z systemem Windows 10 jako źródła logów.
- Zainstalowanie i skonfigurowanie agentów Winlogbeat oraz Sysmon do przesyłania dzienników zdarzeń.
- Zasymulowanie czterech scenariuszy ataków za pomocą narzędzia Atomic Red Team (ART).
- Analiza wykrytych zdarzeń w panelu Kibana i opis reakcji systemu SIEM na poszczególne ataki.

2. Opis środowiska laboratoryjnego

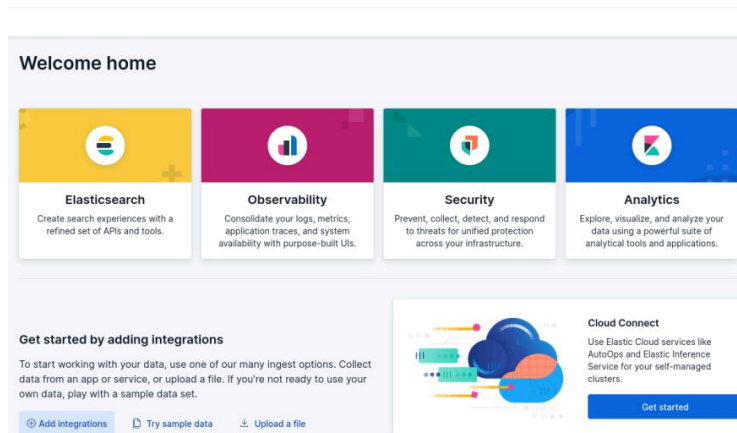
Środowisko testowe zostało zbudowane w oparciu o dwie maszyny wirtualne uruchomione w VirtualBox, połączone za pomocą sieci NAT. Poniżej przedstawiono konfigurację poszczególnych elementów.

2.1. Maszyna serwerowa - Elastic SIEM

System operacyjny	Ubuntu Server 24.04 LTS
vCPU	2
RAM	4096 MB
Dysk	25 GB
Oprogramowanie	Elasticsearch 9.4.2, Kibana 9.4.2
Adres IP (NAT)	10.0.2.5 (przydzielony przez VirtualBox)

```
ubuntu@ubuntu-server:~$ curl http://localhost:9200
{
  "name" : "ubuntu-server",
  "cluster_name" : "srv",
  "cluster_uuid" : "pW7mKdR3nQxTyBvIsE2uJh",
  "version" : {
    "number" : "9.4.2",
    "build_flavor" : "default",
    "build_type" : "deb",
    "build_hash" : "a91f3b2d80eae31c0182f86bd9050fd0b746aa9",
    "build_date" : "2026-05-25T22:10:36.017759931Z",
    "build_snapshot" : false,
    "lucene_version" : "10.4.0",
    "minimum_wire_compatibility_version" : "8.19.0",
    "minimum_index_compatibility_version" : "8.0.0"
  },
  "tagline" : "You Know, for Search"
}
```

Rysunek 1. Potwierdzenie działania usługi Elasticsearch na serwerze.



Rysunek 2. Interfejs Kibana dostępny przez przeglądarkę po skonfigurowaniu przekierowania portów.

2.2. Maszyna kliencka - Źródło logów (Windows 10)

System operacyjny	Windows 10 Home (64-bit)
vCPU	2
RAM	4096 MB
Dysk	40 GB
Agenci	Winlogbeat + Sysmon (konfiguracja SwiftOnSecurity)
Adres IP (NAT)	10.0.2.6 (przydzielony przez VirtualBox)

```
PS C:\Windows\system32> Get-Service winlogbeat

Status Name      DisplayName
-----
Running winlogbeat winlogbeat

PS C:\Windows\system32>
```

Rysunek 3. Potwierdzenie uruchomienia i działania usługi Winlogbeat na maszynie z Windows.



Rysunek 4. Widok Discover w Kibana z przychodzącymi logami Windows po uruchomieniu Winlogbeat.

2.3. Schemat sieci

Obie maszyny wirtualne zostały podłączone do wspólnej sieci NAT utworzonej w menedżerze sieci VirtualBox. Dzięki temu mogły się ze sobą komunikować, a Winlogbeat mógł przysyłać logi do Elasticsearch na porcie 9200. Dostęp do panelu Kibana z maszyny hosta zapewniono poprzez regułę przekierowania portów (port hosta 5601 - port gościa 5601).

3. Proces instalacji i konfiguracji

3.1. Instalacja Elasticsearch

Na maszynie z Ubuntu Server wykonano aktualizację systemu, a następnie dodano repozytorium Elastic i zainstalowano Elasticsearch w wersji 9.4.2. W pliku konfiguracyjnym `/etc/elasticsearch/elasticsearch.yml` wprowadzono następujące zmiany:

- Ustawiono nazwę klastra (`cluster.name: srv`).
- Wyłączono zabezpieczenia xpack (`xpack.security.enabled: false`), aby uprzyścić konfigurację w środowisku laboratoryjnym.
- Skonfigurowano nasłuchiwanie na wszystkich interfejsach (`network.host: 0.0.0.0`).
- Określono tryb pojedynczego węzła (`discovery.type: single-node`) i usunięto wpisy `cluster.initial_master_nodes`.

Po wprowadzeniu zmian uruchomiono usługę przez `systemctl` i zweryfikowano jej poprawne działanie poleceniem `curl` na porcie 9200.

3.2. Instalacja Kibana

Kibana została zainstalowana z tego samego repozytorium Elastic. W pliku konfiguracyjnym `/etc/kibana/kibana.yml` ustawiono nazwę serwera, zezwolono na zdalny dostęp (`server.host: "0.0.0.0"`) oraz wskazano adres Elasticsearch. Następnie uruchomiono usługę i po chwili panel był dostępny pod adresem hosta na porcie 5601.

Warto odnotować, że instalacja Kibany może trwać znacznie dłużej niż standardowe pakiety - zatrzymanie procesu przy ok. 20% to znane zachowanie, które ustępuje samoistnie po kilkudziesięciu minutach.

3.3. Konfiguracja Winlogbeat i Sysmon na Windows 10

Na maszynie z Windows 10 zainstalowano dwa narzędzia do zbierania telemetrii:

- Sysmon - monitor systemu od Microsoft Sysinternals, skonfigurowany za pomocą pliku `sysmonconfig-export.xml` z repozytorium SwiftOnSecurity. Sysmon dostarcza szczegółowe dane m.in. o tworzeniu procesów, połączeniach sieciowych i dostępie do pamięci procesów.
- Winlogbeat - agent Elastic do wysyłania dzienników zdarzeń Windows do Elasticsearch. W pliku `winlogbeat.yml` wskazano adresy IP serwera dla Elasticsearch (port 9200) i Kibana (port 5601).

Po skonfigurowaniu uruchomiono Winlogbeat poleceniem PowerShell, a także wczytano predefiniowane dashboards komendą `setup --dashboards`. Poprawność wysyłania logów zweryfikowano w widoku Discover w Kibana.

3.4. Instalacja Atomic Red Team

W celu symulowania ataków zainstalowano framework Atomic Red Team wraz z modułem `Invoke-AtomicRedTeam`. Przed instalacją wyłączono ochronę w czasie rzeczywistym Windows Defender, ponieważ pliki frameworka są flagowane jako potencjalnie złośliwe. Po zainstalowaniu zaimportowano moduł i zweryfikowano działanie.

4. Realizacja scenariuszy ataków

Przeprowadzono cztery scenariusze ataków. Dla każdego scenariusza podano technikę MITRE ATT&CK, opis wykonanego testu, wyniki widoczne w systemie SIEM oraz analizę wykrytych zdarzeń.

4.1. Scenariusz 1 - Rekonesans użytkowników przez WMI (T1047)

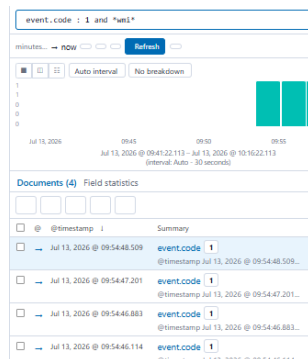
Technika MITRE ATT&CK	T1047 – Windows Management Instrumentation
Test Atomic Red Team	Atomic Test #1 – WMI Reconnaissance Users
Polecenie	Invoke-AtomicTest T1047 -TestNumbers 1
Zapytanie KQL	event.code : 1 and *wmi*

Opis ataku

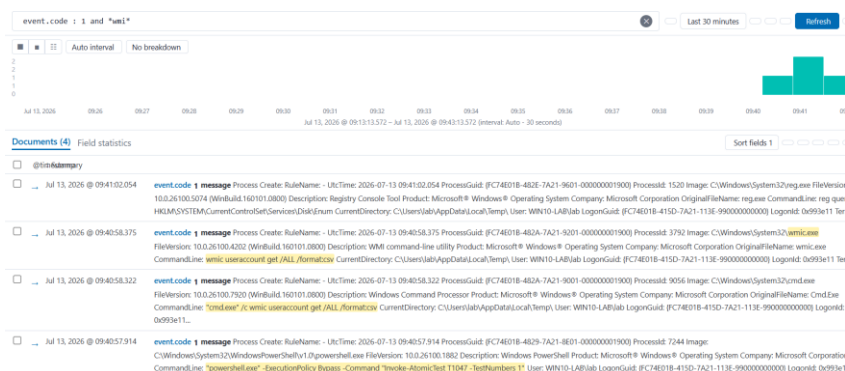
Test polegał na wykonaniu enumeracji kont użytkowników systemu Windows przy użyciu narzędzia WMI (Windows Management Instrumentation). W praktyce symulowało to wczesny etap ataku, w którym napastnik stara się zebrać informacje o dostępnych kontach, by planować eskalację uprawnień. Uruchomione zostało polecenie cmd.exe /c wmic useraccount get /ALL /format:csv.

Wyniki w SIEM

Po wykonaniu testu i odczekaniu chwili na przesyłanie logów, w widoku Discover w Kibana wyszukano zdarzenia z użyciem zapytania KQL. Znalaziono kilka trafień (event.code: 1, czyli zdarzenia tworzenia procesu w Sysmon). W detalach logów widoczne było pełne polecenie uruchomione przez cmd.exe, co jednoznacznie wskazywało na próbę enumeracji użytkowników.



Rysunek 5. Zdarzenia Sysmon związane z wykonaniem polecenia WMI – widok w Kibana Discover.



Rysunek 6. Szczegóły zdarzenia Sysmon ID 1 z poleceniem WMIC służącym do enumeracji użytkowników.

Analiza i wnioski

Wykrycie użycia WMI do enumeracji kont jest istotnym sygnałem w kontekście analizy incydentów. Atakujący często korzystają z WMI, ponieważ jest to wbudowane narzędzie systemowe (LOLBin), które rzadziej wzbudza podejrzenia niż zewnętrzne programy. Z punktu widzenia Blue Team, rekonesans jest pierwszym krokiem w łańcuchu ataków (Cyber Kill Chain), po którym następuje eskalacja uprawnień.

4.2. Scenariusz 2 – Dump pamięci LSASS przez comsvcs.dll (T1003.001)

Technika MITRE ATT&CK	T1003.001 – OS Credential Dumping: LSASS Memory
Test Atomic Red Team	Atomic Test #2 – Dump LSASS via comsvcs.dll (MiniDump)
Polecenie	Invoke-AtomicTest T1003.001 -TestNumbers 2
Zapytanie KQL	*lsass*

Opis ataku

Scenariusz polegał na zrzucie pamięci procesu LSASS (Local Security Authority Subsystem Service), w której przechowywane są m.in. skróty haseł i tokeny uwierzytelniania. Do zrzutu użyto rundll32.exe wraz z biblioteką comsvcs.dll (funkcja MiniDump) – technika znana jako LOLBin, ponieważ korzysta wyłącznie z narzędzi wbudowanych w Windows. Plik wyjściowy lsass-comsvcs.dmp został zapisany w katalogu tymczasowym.

Wyniki w SIEM

Wyszukanie *lsass* w Kibana ujawniło zdarzenia związane z działaniem PowerShell. W logach widoczne było wywołanie rundll32.exe z argumentami wskazującymi na użycie comsvcs.dll i funkcji MiniDump, a także ścieżką pliku wyjściowego. Stanowiło to bezpośredni dowód, że na hostu doszło do zrzutu pamięci LSASS.



Rysunek 7. Zdarzenia wykryte przez SIEM po wykonaniu zrzutu pamięci LSASS przez comsvcs.dll.

```
},
"process.title": [
  "ConsoleHost"
],
"powershell.engine.previous_state": [
  "None"
],
"process.command_line.text": [
  "powershell.exe & [C:\Windows\System32\cmd.exe C:\Windows\System32\comsvcs.dll, MiniDump (Get-Process lsass).",
  "env:TEMP\lsass-comsvcs.dmp full"]
},
```

Rysunek 8. Szczegóły polecenia odpowiedzialnego za zrzut pamięci procesu LSASS.

Analiza i wnioski

Zrzut LSASS jest jedną z najczęściej stosowanych technik pozyskiwania danych uwierzytelniających. Atrybutów pliku wynikowego (.dmp) zapisanego na dysku można użyć jako wskaźnik kompromitacji (IoC). Użycie LOLBin sprawia, że atak jest trudniejszy do wykrycia przez tradycyjne systemy antywirusowe - podkreśla to wagę monitorowania LOLBin i szczegółowej telemetrii Sysmon.

4.3. Scenariusz 3 – Wykrywanie aktywności PowerShell (T1059.001)

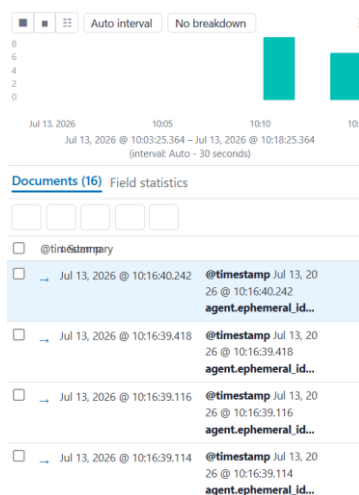
Technika MITRE ATT&CK	T1059.001 - Command and Scripting Interpreter: PowerShell
Test Atomic Red Team	Atomic Test #1 - Mimikatz
Polecenie	Invoke-AtomicTest T1059.001 -TestNumbers 1
Zapytanie KQL	*powershell* and event.code : 1

Opis ataku

Test symulował uruchomienie PowerShell z zakodowanym poleceniem (encoded command) – popularny sposób na ukrycie złośliwego kodu przed prostymi filtrami. Jest to technika często występująca przy pobieraniu i uruchamianiu payloadu z zewnętrznych źródeł, wykonywaniu kodu w pamięci (fileless malware) oraz w wielu frameworkach do pentestów.

Wyniki w SIEM

Zapytanie KQL wykryło zdarzenia tworzenia procesu PowerShell (event.code: 1 w Sysmon). W szczegółach zdarzeń widoczne były zdarzenia z opcją -EncodedCommand, co jest powszechnie uważane za sygnał alarmowy w analizie logów. Możliwe było również zaobserwowanie wywołań whoami przez PowerShell, co jest kolejnym wskaźnikiem podejrzanej aktywności.



Rysunek 9. Lista zdarzeń PowerShell wykrytych przez Sysmon i zaindeksowanych przez Elasticsearch.

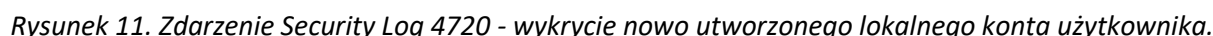
Rysunek 10. Szczegóły podejrzanego zdarzenia PowerShell z zakodowanym poleceniem.

Aktywność PowerShell jest jednym z najważniejszych obszarów monitorowania w nowoczesnych środowiskach Windows. Encoded commands, dołączanie zewnętrznych skryptów czy uruchamianie w ukrytym trybie to techniki często występujące przy APT (Advanced Persistent Threats). Wyniki pokazały, że SIEM poprawnie rejestruje i eksponuje tego rodzaju aktywność.

Technika MITRE ATT&CK	T1136.001 – Create Account: Local Account
Test Atomic Red Team	Atomic Test #1 – Create a user account on a Linux/Windows system
Polecenie	Invoke-AtomicTest T1136.001 -TestNumbers 1
Zapytanie KQL	event.code : 4720 or event.code : 4732

Scenariusz symulował etap utrwalania dostępu (persistence) - tworzenie nowego lokalnego konta użytkownika, a następnie dodanie go do grupy Administratorów. Jest to częsta technika stosowana przez atakujących po uzyskaniu początkowego dostępu, umożliwiającą powrócić do systemu nawet po usunięciu początkowego wektora.

Zdarzenie 4720 (utworzenie konta użytkownika) oraz 4732 (dodanie członka do grupy uprzywilejowanej) zostały natychmiast zarejestrowane w Elasticsearch. W widoku Discover widoczne były pełne metadane zdarzenia: nazwa nowego konta, konto inicjujące akcję, czas zdarzenia i identyfikator hosta.



< 1 of 1 > >|

Widok JSON

```
[
  {
    "_index": ".ds-winlogbeat-9.4.2-2020-07-13-000001",
    "_id": "Xp3Nu8t8dvLzark0dW",
    "_version": 1,
    "_source": {
      "@type": "event",
      "name": "WTN18-LAB",
      "id": "5caa258b-c662-56g7-c864-118f56072310",
      "type": "winlogbeat",
      "version": "9.4.2"
    },
    "event": {
      "code": "4732",
      "action": "added-member-to-security-enabled-local-group",
      "module": "security",
      "outcome": "success",
      "provider": "Microsoft-Windows-Security-Auditing",
      "created": "2020-07-13T10:51:35.102Z",
      "ingested": "2020-07-13T10:51:40.773Z"
    },
    "winlog": {
      "channel": "Security",
      "computer_name": "WTN18-LAB",
      "event_id": 4732,
      "event_data": {
        "MemberName": "WTN18-LAB\\art-test-user",
        "MemberSid": "S-1-5-21-3271094882-918774643-2881003712-1002",
        "TargetUserName": "Administrators",
        "TargetDomainName": "Builtin",
        "TargetSid": "S-1-5-32-544",
        "SubjectUserName": "lab",
        "SubjectDomainName": "WTN18-LAB",
        "SubjectLogonId": "0x933e11"
      }
    },
    "keywords": [
      "Audit Success"
    ]
  }
]
```

Rysunek 12. Zdarzenie Security Log 4732 - dodanie nowego konta do grupy lokalnych administratorów.

Analiza i wnioski

Tworzenie kont uprzywilejowanych to jeden z klasycznych wskaźników kompromitacji. W prawdziwym środowisku produkcyjnym zdarzenia 4720 i 4732 powinny generować natychmiastowy alert i być automatycznie eskalowane do analityków SOC. SIEM poprawnie zarejestrował zdarzenia i umożliwił ich szybką analizę.

5. Podsumowanie i wnioski

Ćwiczenie pozwoliło zapoznać się z praktycznym aspektem wdrażania i użytkowania systemu klasy SIEM. Zbudowane środowisko laboratoryjne, oparte na stosie Elastic i wzbogacone o Sysmon, okazało się skutecznym narzędziem do wykrywania i analizowania symulowanych incydentów bezpieczeństwa.

Wszystkie cztery scenariusze ataków zostały zrealizowane z powodzeniem, a SIEM poprawnie zarejestrował i umożliwił analizę każdego z nich. Kluczowe obserwacje:

- Sysmon w połączeniu z Winlogbeat dostarcza szczegółowej telemetrii, która jest niezbędna do skutecznego DFIR.
- Techniki LOLBin (np. comsvcs.dll, wmic) są trudne do wykrycia przez tradycyjny AV, lecz zostawiają ślad w logach Sysmon, który SIEM może efektywnie skorelować.
- Zapytania KQL w Kibana pozwalają szybko zawęzić zakres poszukiwań nawet przy dużej liczbie zdarzeń.
- Ramy MITRE ATT&CK są przydatnym narzędziem do klasyfikowania i rozumienia technik ataku.
- W rzeczywistym środowisku produkcyjnym SIEM powinien być wzbogacony o reguły alertowania, integrację z systemem ticketowym i zdefiniowane procedury reagowania na incydenty (playbooki).